

ISO 27001:2022 – 7.2 Competencia

a) Determinación de la competencia necesaria

La organización identifica como competencia necesaria para las personas que realizan trabajos que afectan el desempeño en seguridad de la información:

- Para el Responsable de Seguridad de la Información (RSI):

Conocimientos avanzados en administración de sistemas Linux (Ubuntu/Debian), gestión de bases de datos PostgreSQL, administración de Moodle, redes segmentadas TCP/IP con VLANs para CPD1 y CPD2, configuración segura de servidores HTTP/HTTPS (Apache/Nginx), gestión de servidor de correo electrónico (Postfix/Dovecot), protección de activos críticos (backups, firewalls, IDS/IPS), y respuesta ante incidentes de seguridad.

- Para el Responsable del Plan de Dirección de Seguridad (PDS):

Habilidades en elaboración y mantenimiento del PDS, evaluación de riesgos específicos en entornos educativos (acceso a datos de menores, uso de Wi-Fi por tutores legales, etc.), gestión de accesos diferenciados por perfiles (alumnado, profesorado, tutores legales/Wi-Fi, AMPA, administración, equipo directivo), cumplimiento de procesos críticos como iPASEN (gestión de matrícula/calificaciones), SÉNECA (expedientes académicos) y Aula Virtual (Moodle), así como conocimiento de normativa LOPDGDD y protección de datos de menores.

- Para usuarios generales (alumnado, profesorado, personal de administración, tutores legales, AMPA):

Competencia básica en uso seguro de credenciales (contraseñas robustas, no compartirlas), manejo de acceso único con iPASEN/SÉNECA/Moodle, navegación web segura con Mozilla Firefox (evitar descargas sospechosas, verificar HTTPS), identificación de correos de phishing, y procedimiento de reporting de incidencias (robo de credenciales, comportamiento anómalo en búsqueda de información o uso de Internet).

b) Garantía de la competencia

La organización garantiza la competencia mediante:

- Selección inicial basada en titulación:
 - o Para el RSI: Titulación superior en Informática, Telecomunicaciones o Ciberseguridad (grado o máster), o certificaciones equivalentes (CCNA, Linux Professional Institute, CompTIA Security+).
 - o Para el Responsable del PDS: Formación en gestión de riesgos (ISO 31000), protección de datos (LOPDGDD) y seguridad educativa.
 - o Experiencia mínima de 3 años en entornos educativos o similares para ambos roles.
- Formación obligatoria anual:

- o RSI: Curso de actualización en ciberseguridad específica para CPD1 (PostgreSQL/Linux, hardening de servidores) y CPD2 (Moodle/Linux/correo, segmentación de red con VLANs), impartido por proveedores certificados (ej. INTEF, centros de formación oficiales).
- o Responsable del PDS: Taller anual sobre gestión de accesos por perfiles, evaluación de riesgos en entornos educativos y novedades en protección de datos.
- o Usuarios generales: Formación anual de 1 hora en concienciación en ciberseguridad (uso seguro de credenciales, detección de phishing, reporting de incidencias).

Experiencia práctica verificada:

- Simulacros trimestrales de respuesta ante incidentes: robo/pérdida de portátil protegido (borrado remoto, localización), ataque de fuerza bruta a Moodle, denegación de servicio a servidor de correo.
- Pruebas prácticas de gestión de alarmas y cámaras de seguridad del centro educativo.
- Actualización supervisada de página web y redes sociales del centro (gestión de roles y permisos).

c) Acciones para adquirir competencia necesaria y evaluación de efectividad

Cuando se detecte falta de competencia (mediante auditorías internas, incidencias recurrentes en acceso a Aula Virtual, servidor de correo, o tramitación iPASEN/SÉNECA), se toman las siguientes acciones:

Cursos específicos de refuerzo:

- Administración avanzada de Moodle (gestión de roles, plugins de seguridad).
- Optimización y seguridad de PostgreSQL (copias de seguridad, control de accesos).
- Segmentación de red y firewalls en entorno educativo.
- Evaluación de efectividad: Pruebas prácticas pre/post curso (ej. configurar un rol seguro en Moodle en menos de 30 minutos).

Rotación supervisada:

El personal con carencias rota durante 2 semanas en el Departamento TIC (protegido por puerta con cerradura y control de accesos), bajo supervisión del RSI, para adquirir experiencia práctica en gestión de activos críticos (CPD1, CPD2, backups).

Tutoría o mentoring:

- Asignación de un mentor (RSI o Responsable del PDS) durante 1 mes para seguimiento diario en tareas concretas (gestión de accesos por perfiles, respuesta a incidencias menores).

Reasignación o contratación:

- Si tras dos ciclos de formación la competencia no se alcanza, se reasigna al trabajador a funciones que no impacten la seguridad de la información o se contrata a un profesional competente externo.

Métricas para evaluar efectividad de las acciones:

- Reducción del 70% de errores en tramitación iPASEN/SÉNECA en un plazo de 6 meses.
- Disminución de incidencias de acceso no autorizado a Aula Virtual en un 80% en 3 meses.
- Éxito en simulacros de pérdida de portátil (borrado remoto completado en < 10 minutos) en el 100% de los casos tras la acción formativa.
- Mejora en pruebas trimestrales de competencia (nota media > 8/10).

d) Información documentada como evidencia de competencia

Se conserva la siguiente información documentada:

- Certificados de formación anual y titulaciones:
Almacenados en carpeta segura dentro del Departamento TIC (acceso solo para RSI y equipo directivo), con copia digital en CPD1 cifrada.
- Registros de experiencia y CV validados:
Currículums actualizados y firmados por el trabajador, validados por el responsable de RRHH, con anexo de experiencias prácticas verificadas (simulacros realizados, proyectos compleados).
- Actas de evaluaciones post-acción:
Documento firmado por el evaluador (RSI o consultor externo) tras cada formación, rotación o tutoría, indicando nivel de competencia alcanzado (básico, suficiente, avanzado) y fecha de verificación.
- Informes de auditorías internas sobre competencia:
Evaluaciones periódicas (semestrales) de competencia para cada perfil (usuarios generales, RSI, Responsable del PDS), firmadas por el equipo directivo y el auditor interno.
- Almacenamiento seguro:
Toda la evidencia se guarda digitalmente en CPD1 con acceso restringido (solo RSI y directores), con backup cifrado en CPD2 y retención mínima de 5 años, conforme al procedimiento de control de documentos.